

PDPL Privacy Impact Assessment — Instructor Dashboard

SECTION 04-compliance-ksa TYPE assessment STATUS **draft** OWNER Founder / DPO

UPDATED 2026-08-18

Read with: `pdpl-compliance-program-and-dpia.docx`. That document's DPIA assesses **Captain Adel only** — the question → retrieval → model → storage path. This assessment covers a *different* processing activity: instructor visibility of cadet progress. The two are a set, not rivals.

Why it exists. `06-operations-it/spec-instructor-dashboard.md` §3 states plainly that a cadet's logbook and study data are personal data, that the PDPL DPIA is a launch gate, and that "*cross-user visibility **must** be inside that DPIA's scope.*" This document discharges that requirement.

Status. Assessment of a **planned** system. It must be reviewed and signed **before the Instructor Dashboard ships** — it gates launch, per `compliance-roadmap.md`.

1. The processing being assessed

An instructor at a partner flight academy sees the study progress of cadets in their cohort.

This is a departure from the platform's entire access model. Every existing Firestore rule is `isOwner(uid)`: a user reads their own document and nothing else. The dashboard requires **controlled cross-user reads**, and the spec is explicit that getting the rules wrong is "*the single biggest risk.*"

2. Data flow

The design deliberately avoids the obvious approach. Instructors **never** read `users/{cadetUid}`. Instead:

1. The **cadet's own client** writes a scoped progress summary into the school's subtree — `schools/{schoolId}/roster/{cadetUid}`.
2. Instructors read documents belonging to **the school**, never to the cadet.
3. `users/{uid}` isolation therefore remains 100% intact.

This is a sound pattern and should be preserved: it converts a cross-user read problem into an ordinary same-collection read, and it means a rules mistake exposes a deliberately-minimised summary rather than a full user record.

Personal data in the roster document: `cadetName`, `cadetEmail` (both denormalised for the cohort list), `consent`, the progress summary fields, and instructor-authored notes.

Storage location: Firestore, `me-central2` (Dammam) — in-Kingdom. See §6.

3. Lawful basis and roles under PDPL

The controller/processor split is the load-bearing legal question here, and it differs by customer type:

Context	Fly GACA's role	Basis
B2C individual learner	Controller	Contract / consent, per the privacy notice
Academy cohort (B2B)	Processor for the academy	The academy instructs; terms are in <code>02-legal/b2b-data-processing-agreement-draft-2026-06-14.md</code>

Consent is handled well by the existing design and should not be weakened: enrolment presents an explicit, **revocable** data-sharing consent; revoking from Settings flips the roster entry to `consent: false` and **blanks the shared summary**. Revocation that leaves stale data behind is the usual failure mode, and this design already avoids it.

Cite PDPL Articles 18–23 for data-subject rights, consistent with the existing DPA. Do **not** import GDPR Article 28/35 framing — the structure is comparable, the law is not.

4. Necessity, proportionality, minimisation

The summary must carry what an instructor needs to teach, and nothing more.

Appropriate: readiness indicators, per-topic progress, exam-attempt outcomes, last-active date.

Not appropriate: full logbook entries, complete exam transcripts, Captain Adel chat history, or anything about study outside the cohort's subject. Instructor notes are staff-authored content about an identifiable person and should be treated as personal data subject to access requests.

The risk to guard against over time is drift — a later feature quietly widening the summary until it is a mirror of `users/{uid}`, which is exactly what the architecture was designed to prevent. Any change to the summary's fields should require a return to this assessment.

5. Risk assessment

Likelihood × Impact on the same 1–5 scale used by `09-investor-relations/risk-register.xlsx`, so rows are directly comparable.

#	Risk	L	I	Score	Mitigation
P1	Firestore rule misconfiguration exposes a cadet to the wrong school	3	5	15	Rules unit tests in <code>tests/rules/</code> covering cross-school denial; <code>npm run test:rules</code> in CI before launch

#	Risk	L	I	Score	Mitigation
P2	Instructor retains access after leaving the academy	3	4	12	Seat//roster offboarding tied to the academy's seat management; periodic review
P3	Summary drift re-introduces full logbook detail	3	4	12	Field allow-list; changes require PIA review
P4	Cadet revokes consent but data persists in a cached client or export	2	4	8	Revocation blanks the summary server-side; define export retention
P5	Denormalised <code>cadetEmail</code> propagates beyond the cohort	2	3	6	Confirm the field is needed at all; consider display name only
P6	Instructor notes contain sensitive or adverse commentary the cadet can request	2	3	6	Staff guidance; include notes in DSAR scope

Highest residual risk is P1, and it is a rules problem, not a policy problem — which means the mitigation is a test suite, not a document.

6. Data residency

Firestore is live in `me-central2` (Dammam), in-Kingdom, satisfying the PDPL boundary.

Compute is not. Cloud Functions remain in `me-central1` (Doha, Qatar) — an owner-accepted interim with a documented migration path (`06-operations-it/runbooks/runbook-pdpl-me-central2.md`). Roster reads and writes traverse that compute. This is a known, tracked position rather than a new finding, but it is in scope for this assessment and should be closed before the dashboard carries production cohort data at scale.

Note a documentation conflict flagged separately: `06-operations-it/hosting-facts.md` asserts Cloud Functions are in `me-central2` , while the runbook and `secrets-and-keys-placement.md` say `me-central1` . Two internal documents disagree on a PDPL-load-bearing fact. Resolving this is an action on `compliance-roadmap.md` .

7. Conclusion and sign-off

The design is privacy-positive in its fundamentals: it avoids cross-user reads architecturally, it minimises the shared payload, and it makes consent explicit and revocable with server-side effect. The residual risk is concentrated in **implementation correctness of the Firestore rules**, not in the design.

Recommendation: proceed, conditional on —

1. Firestore rules tests covering cross-school and revoked-consent denial, passing in CI (closes P1).
2. A written field allow-list for the progress summary (closes P3).

3. Confirming whether `cadetEmail` is required in the roster document (closes P5).

4. Instructor-notes guidance, and their inclusion in DSAR scope (closes P6).

Assessed by	Founder / DPO
Date	2026-08-18
Status	Draft — not yet signed
Review trigger	Any change to roster fields, roles, or the consent flow; otherwise annually

Related: `pdpl-compliance-program-and-dpia.docx`, `02-legal/b2b-data-processing-agreement-draft-2026-06-14.md`, `06-operations-it/spec-instructor-dashboard.md`, `cyber-risk-assessment-2026-08.md`.

DRAFT